

SAT 3812: Cyber Security I

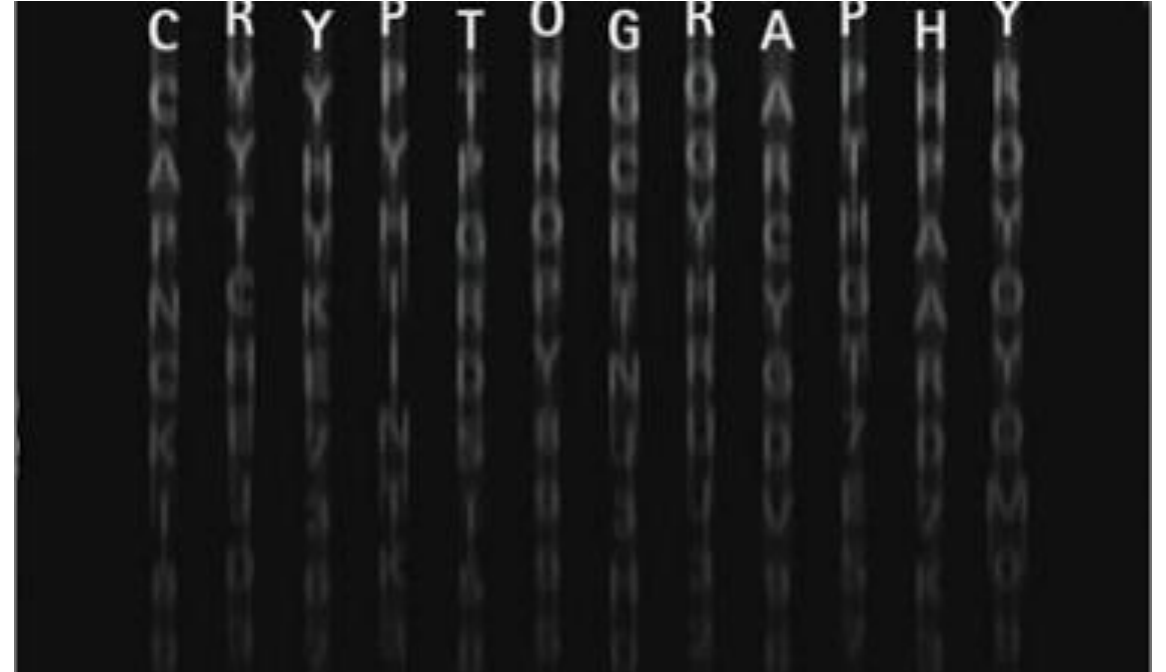
Cryptography

Instructor: Yunlong Xing



Cryptography

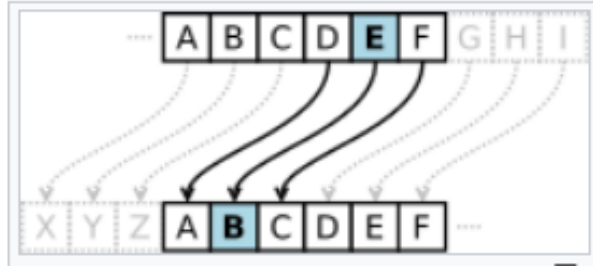
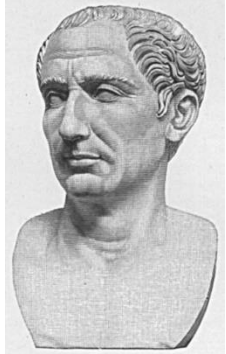
- ◆ Define it
- ◆ How long has it been around?



Cryptography

- Greek words for “Secret Writing”.
 - A cipher is an algorithm for performing encryption or decryption
 - The art of devising ciphers is called cryptography
 - The art of breaking ciphers is called cryptanalysis
- Cryptography is the use of mathematical operations to protect messages traveling between parties or stored on a computer

Brief History of Encryption: Caesar Cipher



Plain	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
Cipher	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W

Plaintext: THE QUICK BROWN FOX JUMPS OVER THE LAZY DOG
Ciphertext: QEB NRFZH YOLTK CLU GRJMP LSBQ QEB IXWV ALD

Julius Caesar credited for cipher

What are weaknesses with this cipher?



Mini-contest!

- Ciphertext:
 - *Wkhuh duh wzr ploolrq grooduv lq pb edqn dffrxqw*
- It is using caesar cipher. Please decipher the original text.

A useful website

<https://www.dcode.fr/cipher-identifier>



Search for a tool

★ SEARCH A TOOL ON dCODE BY KEYWORDS:
e.g. type 'random' 

★ BROWSE THE [FULL dCODE TOOLS' LIST](#)

Results

dCode's analyzer suggests to investigate:

 Warning The text has a short length, this can affect the quantity and reliability of the results (see FAQ)

↑↓	↑↓
ROT Cipher	■■■■■
Caesar Cipher	■■■■■
Mono-alphabetic Substitution	■■■■■

CIPHER IDENTIFIER

Cryptography > Cipher Identifier



ENCRYPTED MESSAGE IDENTIFIER

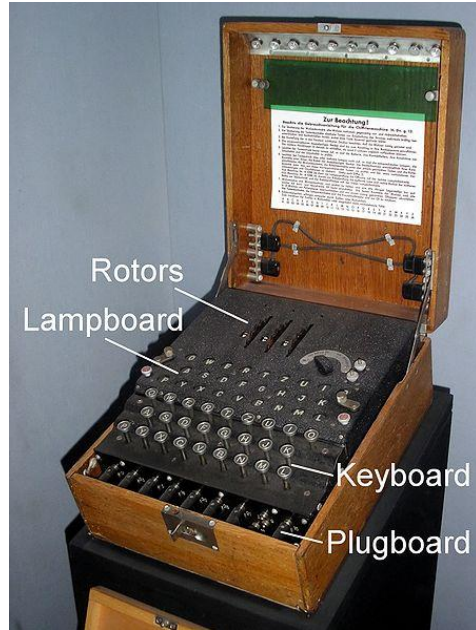
★ CIPHERTEXT TO RECOGNIZE (?)

wkhuh duh wzr ploolrq grooduv lq pb edqn dffrxqw

★ CLUES/KEYWORDS (IF ANY)

 ANALYZE

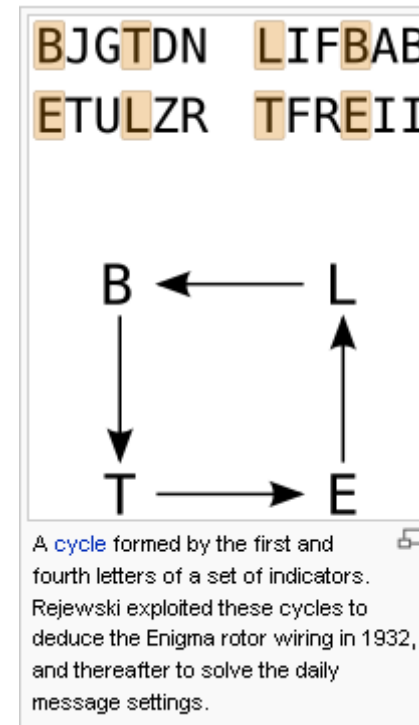
Brief History of Encryption: Enigma Machine



Enigma Machine



Marian Rejewski



Breaking the Enigma

- Britain set up its cryptanalysis team in Bletchley Park
- They consistently broke German codes throughout the war
 - Provided the intelligence codenamed ULTRA
- Important location in the history of computing
 - Alan Turing
 - COLOSSUS

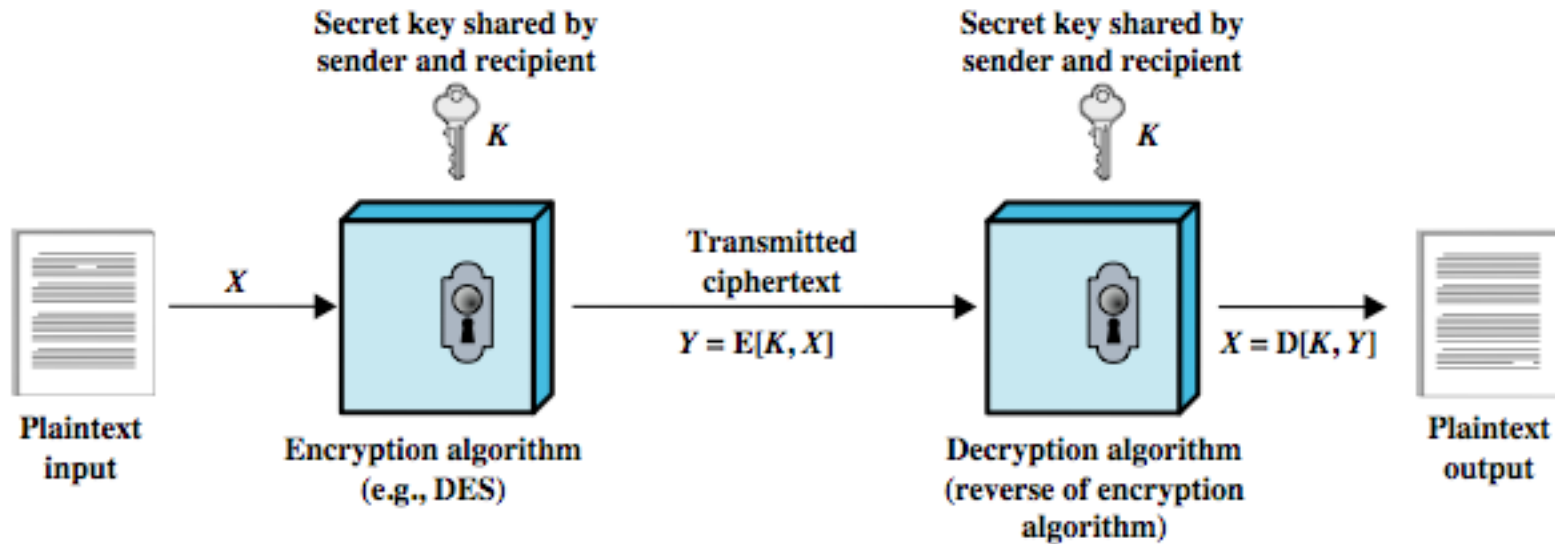
Watch the video

Story: Cracking the NAZI Enigma Code Machine (9min)

<https://www.youtube.com/watch?v=Hb44bGY2KdU>

Modern Symmetric Encryption

Symmetric Encryption



What 2 requirements are needed for secure use of symmetric encryption?

Algorithm, Key

Kerckhofs' Principle

"All crypto algorithms must be public; only the keys are secret"

--- "La Cryptographie Militaire," J. des Sciences Militaires, vol. 9, pp.5-38, Jan. 1883 and pp. 161-191, Feb. 1883.

- Why???
- ◆ Trying to keep the algorithm secret (security by obscurity) never works. Reasons:
 - ❖ Logistic issue: Too much effort to invent, test, and install new algorithm
 - ❖ "Publish the algorithm and let cryptologists to break it. If no one succeeded in 5 years, it must be pretty solid."
 - ❖ One ought to design systems under the assumption that the enemy will immediately gain full familiarity with them
 - ❖ Real secrecy is on the key. Key length is a major design issue

Shannon's maxim

- Kerckhoffs's principle was reformulated (perhaps independently) by Claude Shannon as "The enemy knows the system". In that form it is called Shannon's maxim.
- Why are they equivalent?
 - One ought to design systems under the assumption that the enemy will immediately gain full familiarity with them

What is "security through obscurity"

- Security Through Obscurity (STO) is the belief that a system of any sort can be secure so long as nobody outside of its implementation group is allowed to find out anything about its internal mechanisms.
 - For example, you hide a home key outside your home where no one will find it!

Discussion:

- Obscurity is a bad example of the Kirchhoff's principle?

or

- Obscurity is a Valid Security Layer?

What is "security through obscurity"

- Both the automobile industry and the medical device industry rely heavily on the principle of "Security Through Obscurity".
 - It is hard for people to find details on their proprietary implementations.
- These systems used to be "safe" enough because nobody have access to them...
- However, today's devices are increasingly connected wirelessly, thus open doors for hackers to explore internal vulnerabilities of these systems.
- Is "security through obscurity" enough to protect your products in the near future?

A shame: DVD Encryption

- The scheme to protect DVDs was broke since 1999. It was designed in 1996 by entertainment industry to prevent piracy.
- The scheme (called CSS) is seriously flawed:
 - 40-bit key
 - Every DVD player has one of the 400 CSS keys.
 - Every DVD can be decrypted by any of the 400 keys.
 - That key is encrypted within the DVD player.
 - Both encrypted data and decrypted data are available on computer.

How to break DVD encryption

- Reverse engineered Xing's DVD player to find one **unencrypted** key. Then more keys.
- The DVD protection scheme is officially dead now.
- The lesson: This is yet another example of an industry meeting in secret and designing a proprietary encryption algorithm that ends up being embarrassingly weak.
- I never understand why people don't use open, published, trusted encryption algorithms and protocols.

Attacking Symmetric Encryption

2 Types of Symmetric Encryption Attacks

- Brute-force attack
- Cryptanalysis
 - Statistical analysis
 - Differential analysis

Exhaustive Key Search

Key Size (bits)	Number of Alternative Keys	Time Required at 1 Decryption/ μ s	Time Required at 10^6 Decryptions/ μ s
32	$2^{32} = 4.3 \times 10^9$	$2^{31} \mu s = 35.8$ minutes	2.15 milliseconds
56	$2^{56} = 7.2 \times 10^{16}$	$2^{55} \mu s = 1142$ years	10.01 hours
128	$2^{128} = 3.4 \times 10^{38}$	$2^{127} \mu s = 5.4 \times 10^{24}$ years	5.4×10^{18} years
168	$2^{168} = 3.7 \times 10^{50}$	$2^{167} \mu s = 5.9 \times 10^{36}$ years	5.9×10^{30} years
26 characters (permutation)	$26! = 4 \times 10^{26}$	$2 \times 10^{26} \mu s = 6.4 \times 10^{12}$ years	6.4×10^6 years

Question: For a given encryption algorithm, if the key is 63 bits, it takes 100 hours to break it; then if the key is 65 bits, how long does it take to break it?

Basic Cipher Attacks for Mono-alphetic Substitution

- Use statistical properties of natural languages.
- Rank of Frequency of appearance of
 - Unigrams (single letter): e, t, o, a, n, i etc
 - Digrams (two-letter): th, in, er, re, an, etc
 - Trigrams (three-letter): the, ing, and , ion, etc
- Counting the frequencies of letters in ciphertext.
- Tentatively assign the most common one to e; next to t...
- ◆ Then look at the trigrams of decipher text, if "tXe" appears, it should be "the"! Original deciphering function should be changed to map from X to h.
- ◆ Similarly, what should we do if we see "thYt"?
- ◆ How about "aZW"?

Cipher Attack Example: Guess a Probable Word

- Ciphertext from accounting firm
CTBMN BYCTC BTJDS QXBNS GSTJC BTSWX CTQTZ CQVUJ Q/SGS T/QZZ MNQJS VLNSX
VSZJU JDSTS JQUUS JUBXJ DSKSU JSNTK BGAQJ ZBGYQ TLCTZ BNYBN QJSW
- A likely word is financial.
- ◆ **Based on two i are separated by four letters, we look for same pattern in ciphertext.**
- ◆ **There are 12 hits, position 6, 15, 27, 31, 42, 48, 56. 66, 70, 71, 76, and 82.**
- ◆ **Only 31 and 42 has the next letter n (ana) separated by one letter. Furthermore, only 31 also has the a correctly positioned, so we know that financial begins at position 30.**
- ◆ **You can use the frequency statistics for English to continue.**
- ◆ **Solve this problem yourself. Will be in exam or quiz.**

Watch the video if time allowed

Story: Mary Queen of Scot's Cipher (7 min)

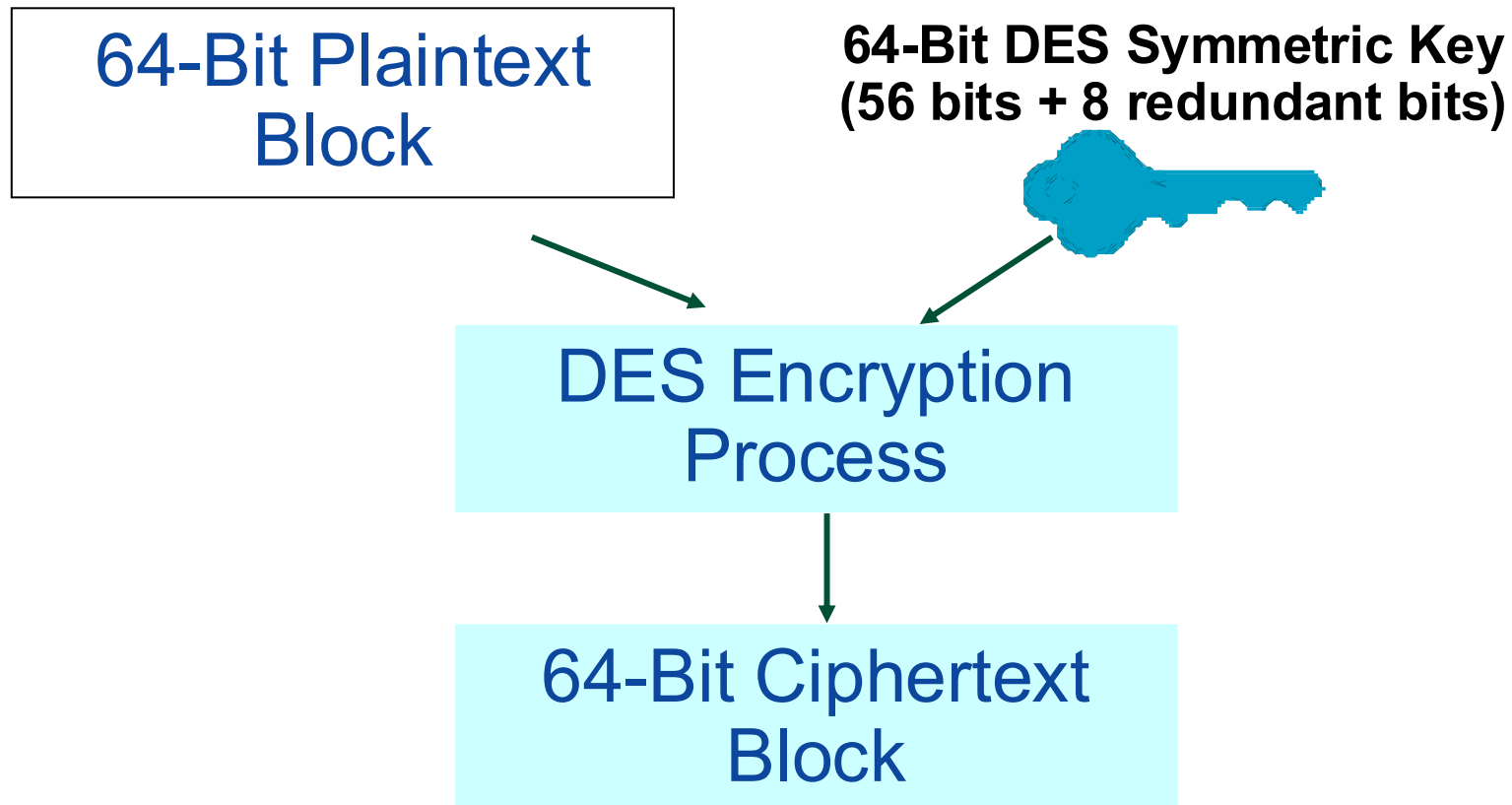
https://www.youtube.com/watch?v=_htopuN4pCk

Symmetric Encryption Algorithms

	RC4	DES	3DES	AES
Key Length (bits)	40 bits or more	56	112 or 168	128, 192, or 256
Key Strength	Very weak at 40 bits	Weak	Strong	Strong
Processing Requirements	Low	Moderate	High	Low
RAM Requirements	Low	Moderate	Moderate	Low
Remarks	Can use keys of variable length	Created in the 1970s	Applies DES three times with two or three different DES keys	Today's gold standard for symmetric key encryption

Data Encryption Standard (DES)

- DES used to be a widely used encryption scheme (no longer now)
 - Uses 64 bit plaintext block and 56 bit key to produce a 64 bit ciphertext block



Concerns about DES

- What are the concerns about DES?
 - ◆ Too weak
- Solution?
 - ◆ Longer Key

Triple DES (3DES)

To prolong the life of DES -> 3 DES was incorporated in 1999

- Key features
 - repeats basic DES algorithm three times
 - using either two or three unique keys
- Drawback of 3DES?
**Too slow,
Repeat weakness 3 times won't make you strong!**

A Question About 3DES

- Why 3 times of DES?
 - Why can't we do more than 3 times to further increase the security?

Too slow if more than 3 times

Advanced Encryption Standard (AES)

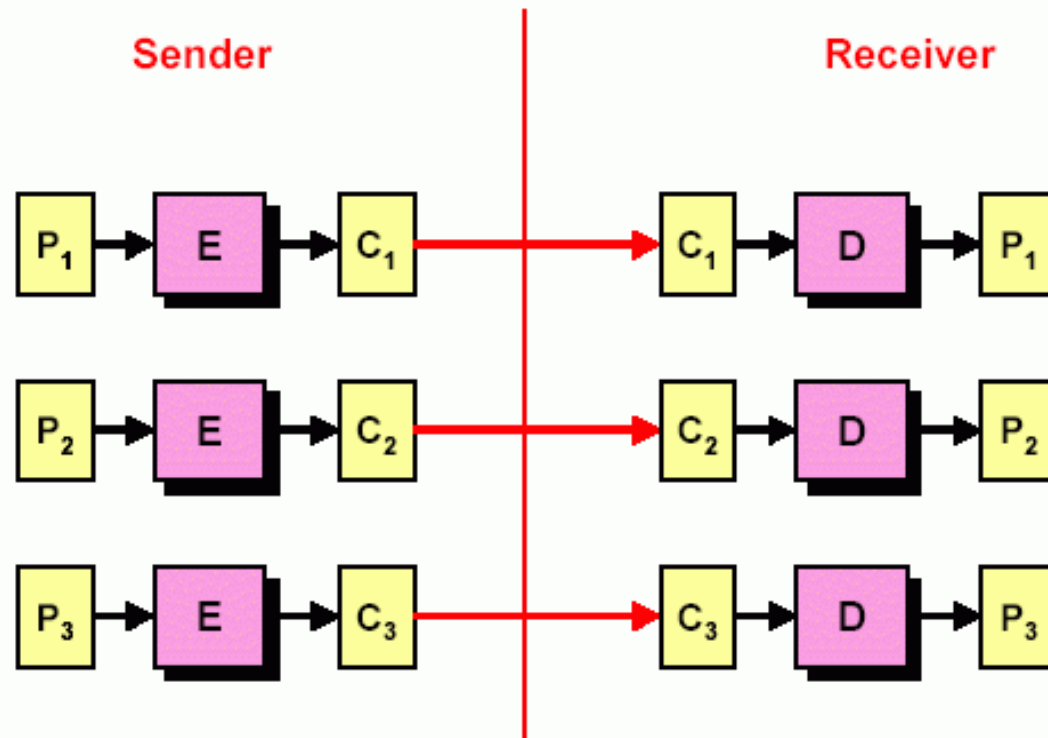
- Why the need for AES?
- NIST called for proposals in 1997
- What were AES Requirements?
 - symmetric block cipher
 - uses 128 bit data block & 128/192/256 bit keys
 - runs fast in both software and hardware,
 - is easy to implement
 - requires little memory
 - is now widely available commercially

DES, 3DES, and AES Comparison

	DES	3DES	AES
Key Length (bits)	56	112 or 168	128, 192, 256
Strength	Weak	Strong	Strong
Processing Requirements	Moderate	High	Modest
RAM Requirements	Moderate	High	Modest

Encryption Mode

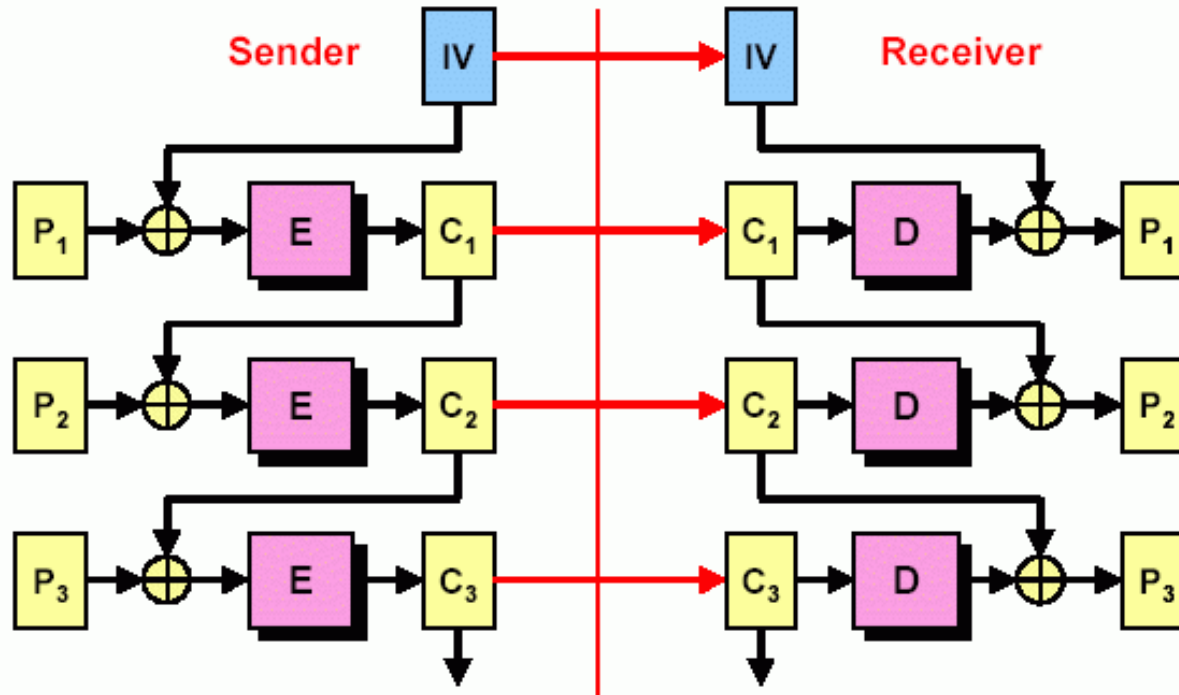
- Encryption Mode: answer the question of how to deal with a lot of data
- **Electronic Code Book (ECB)** mode for block ciphers of a long digital sequence: Simplest



P: plaintext
C: ciphertext
E: encryption
D: decryption

Cipher Block Chaining (CBC) Mode

- Cipher Block Chaining (CBC) mode



- IV = Initialization Vector - use only once; add randomness
- $\oplus$ XOR operation (Exclusive OR)

XOR Operator

- XOR operation (Exclusive OR)

- Tell whether A and B are different

- Why XOR in Cryptography?

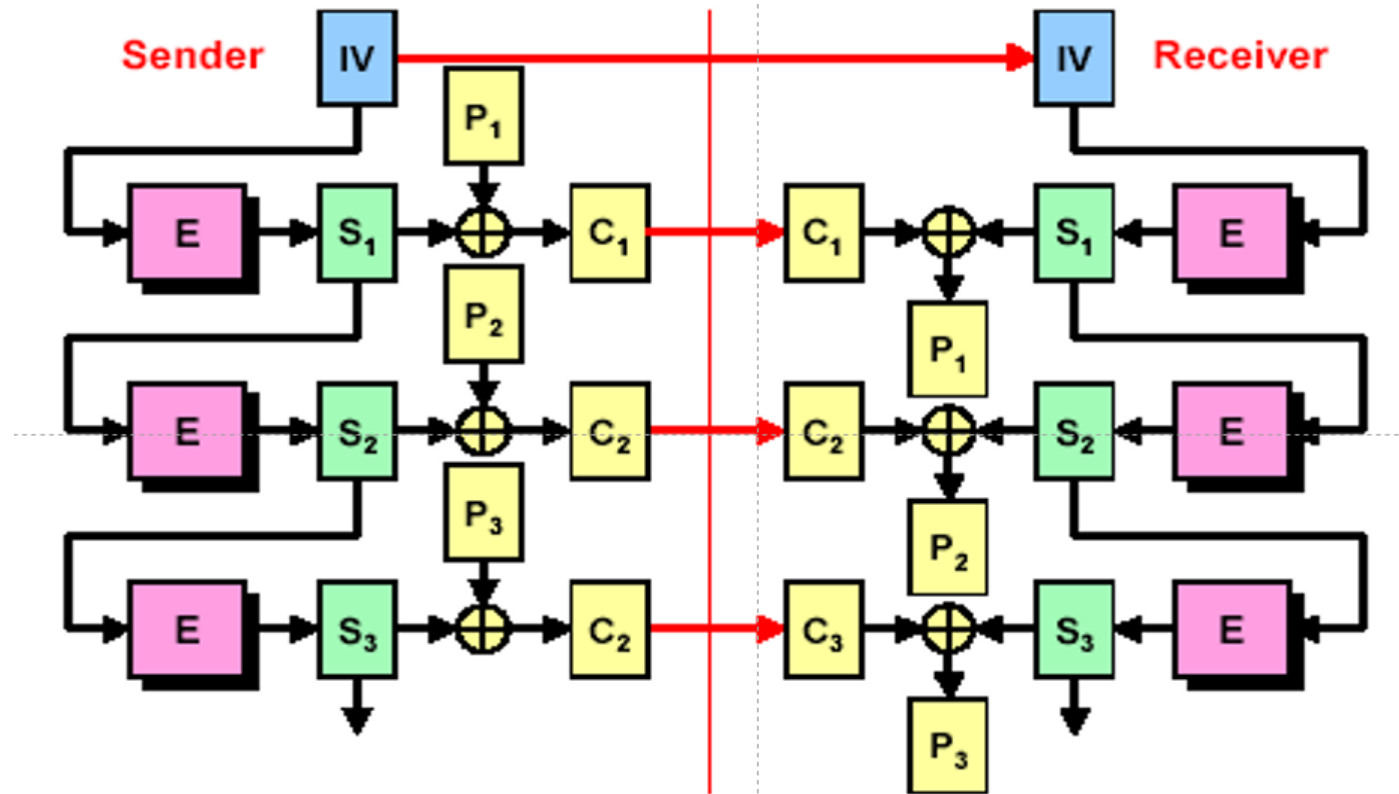
- XOR output has a balanced 0s and 1s; AND/OR do not have a balanced 0s and 1s for output
 - XOR is reversible.

$$A \text{ XOR } B = C \Rightarrow C \text{ XOR } A = B$$

Input		Output
A	B	A xor B
0	0	0
0	1	1
1	0	1
1	1	0

X	Y	AND(X,Y)	OR(X,Y)	NAND(X,Y)	NOR(X,Y)	XOR(X,Y)
0	0	0	0	1	1	0
0	1	0	1	1	0	1
1	0	0	1	1	0	1
1	1	1	1	0	0	0

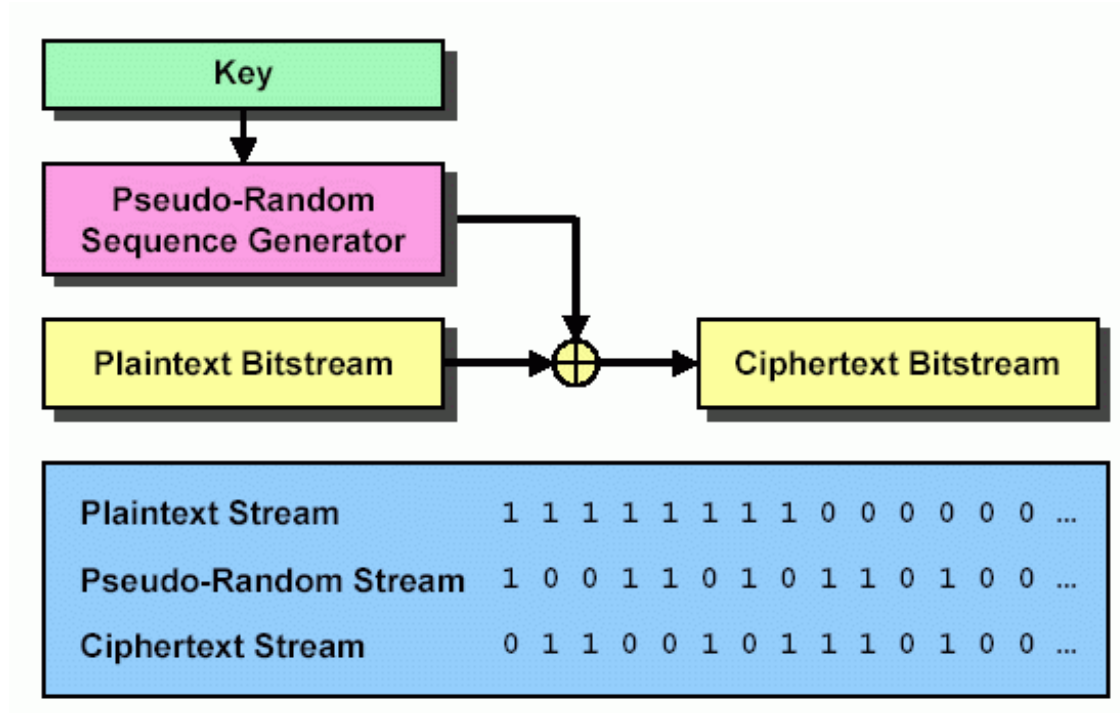
Output Feedback (OFB) mode



OFB Advantages vs CBC:

1. Same method for both encryption and decryption
2. No need for plaintext padding
3. Random access of encrypted data. CBC must be decrypted sequentially.
4. No error propagation for plaintext.

Stream Cipher



- Rather than divide bit stream into discrete blocks, XOR each bit of your plaintext continuous stream with a bit from a pseudo-random sequence

Quantum cryptography

- Quantum cryptography is the science of exploiting quantum mechanical properties to perform cryptographic tasks.
- The best known example of quantum cryptography is quantum key distribution which offers an information-theoretically secure solution to the key exchange problem

A useful website

<https://icyberchef.com/>

Operations

aes

AES Decrypt

AES Encrypt

Parse ASN.1 hex string

Group IP addresses

Parse IPv6 address

Defang IP Addresses

Generate all hashes

Extract IP addresses

Format MAC addresses

Extract MAC addresses

Parse Raw Ciphertext

Recipe

AES Encrypt

Key

11111111111111111111111111111111

HEX

IV

22222222222222222222222222222222

HEX

Mode

CBC

Input

Raw

Output

Hex

Input

length: 14

lines: 1

This is a test

Output

time: 1ms

length: 32

lines: 1

60bd691690046d0bf96633869ab408f4

Mini-contest!

- Use AES 256 to encrypt the following text
 - Key in UTF8 text: 1111111111111111
(16 of 1s)
 - Same IV
 - CBC mode
 - Plain text: I like cybersecurity
- What are the first 4 numbers in cipher text?

Mini-contest!

- Use DES to decrypt the following text
 - Cipher text: 112203dc1d4609f4c3b1f69d07c50750
 - Key in UTF8 text: 11111111
(8 of 1s)
 - Same IV
 - CBC mode
- What is the original plain text?

Mini-contest!

- Crack the following ciphertext
 - 00110011 01110000 01100001 01111000 01111001 00110000
00110111 00110011

Mini-contest!

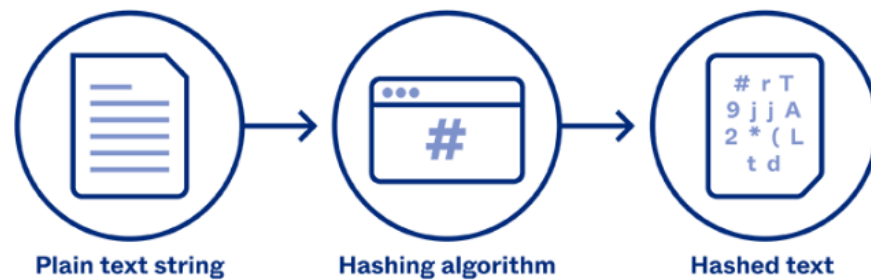
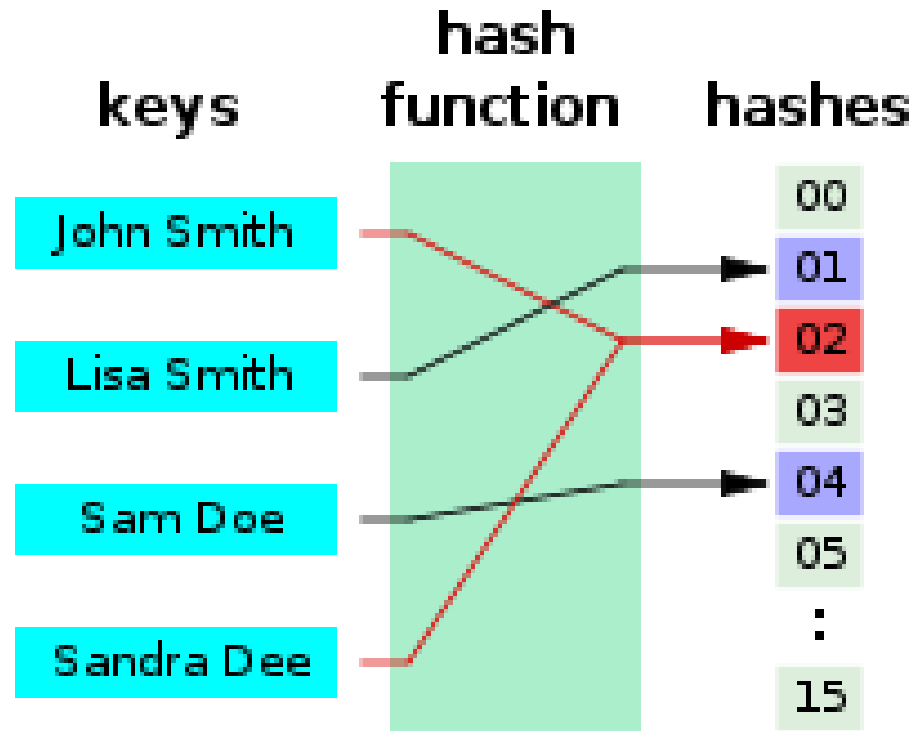
- Crack the following ciphertext
 - guvf vf n ebggra zrffntr

Hashing

Hashing

- Hashing
 - Hashing is the process of transforming a given string into another **shorter and fixed-length** string.
 - Hashing is a **one-way function** that turns a string into a **unique digest** of the original string.
 - Hashing is widely used, such as shadow password in Linux, or digital signature

A hash example



Why Hashing?

- Integrity checking
 - Faster than processing the original messages
- Protecting data
 - Hash password
- Collision resistance
 - Avoid attacks

Another Example: MD5 Hashing

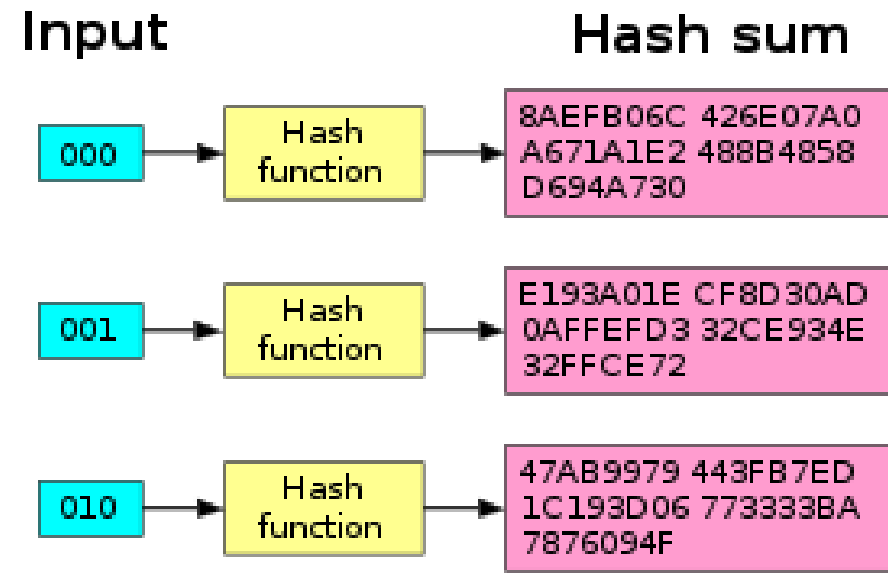
MD5 "The quick brown fox jumps over the lazy *dog*" =
9e107d9d372bb6826bd81d3542a419d6

MD5 "The quick brown fox jumps over the lazy *cog*" =
1055d3e698d289f2af8663725127bd4b

What do you see from these two hashes?

- **Same length**
- It is impossible to guess the original message (**one-way**)
- The results are so different (**collision resistance**)

Hashing: avalanche effect

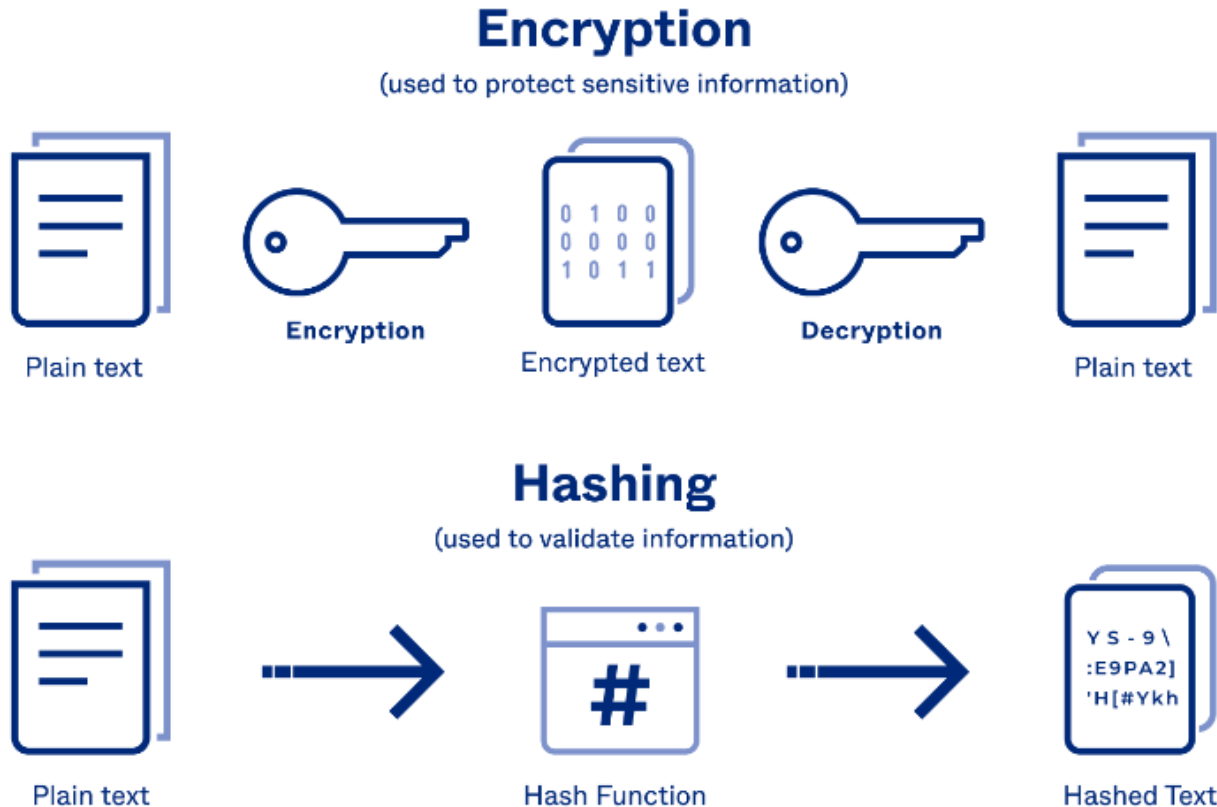


If an input is changed slightly, the output changes significantly.
This is what we want for hashing.

Hashing versus Encryption

Discussion:

What are the differences between encryption and hash?



Hashing versus Encryption

Characteristic	Encryption	Hashing
Result length	About the same length as the plaintext	Short fixed length regardless of message length
Reversible?	Yes. Decryption	No. There is no way to get from the short hash back to the long original message

Hash and encryption are often used together.

Hashing examples

- Student $x \rightarrow$ Birthday $H(x)$
- Student $x \rightarrow$ M number $H(x)$
- SSN $x \rightarrow$ Name $H(x)$
- Which is better hash?

Three hashing rules:
1) Same length output
2) One way
3) No collision

Attacking Hashes

- How are hashes attacked?
 - brute-force attack
 - attempt many inputs
 - cryptanalysis
 - exploit logical weakness in algorithm

Common Hash Functions

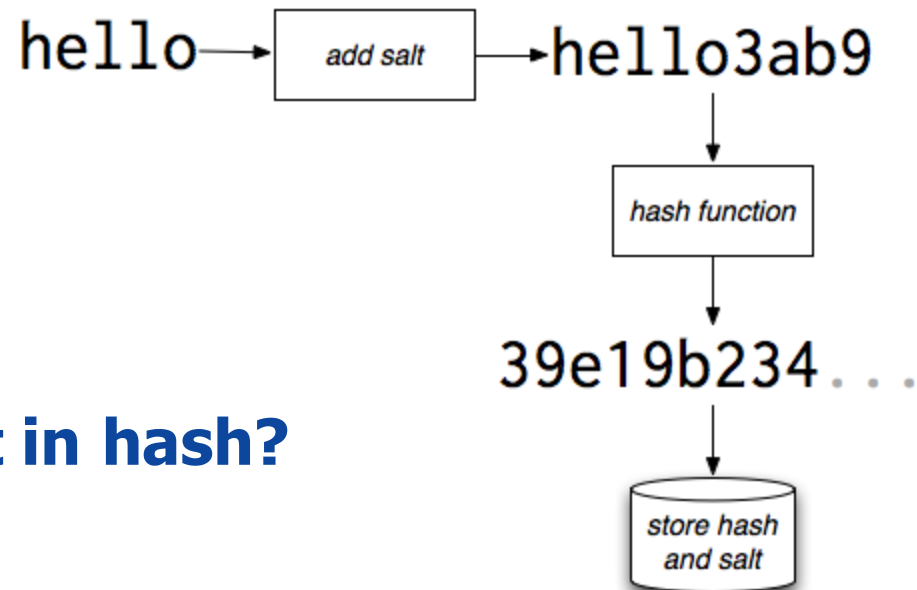
- MD4
 - "MD" stands for "Message Digest."
 - Designed by Rivest.
 - The algorithm has influenced later designs, such as the MD5 and SHA-1 algorithms
 - No longer safe to use.
- MD5
 - Designed by Rivest
 - it gives 128-bit hash (a little short)
 - MD5 was defeated by a mathematician in 2004
 - Not safe, only used in non-critical situation (like file checksum)

Common Hash Functions

- SHA series hash functions
 - most widely used hash algorithm
 - SHA-1 gives 160-bit hash
 - SHA-2 series (SHA-256, SHA-384, SHA-512) provide improved size and security
 - SHA-3 series in 2015
 - New design.
 - A future backup algorithm for SHA-2
- Note: MD5 and SHA-1 should not be used because they have been shown to be unsecure
- SHA-2 and SHA-3 are still ok.

Salting and Hashing

- To make hashing more secure, we can randomize the hashes by appending or prepending a random string, called a salt, to the original text before hashing.



Why use salt in hash?

A useful website

<https://crackstation.net/>

CrackStation

CrackStation Password Hashing Security Defuse Security

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

7e60bc642fefc11b43792e8745df6c1d

I'm not a robot

reCAPTCHA

Privacy - Terms

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
7e60bc642fefc11b43792e8745df6c1d	md5	cyber

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

Mini-contest!

- Get md5 hash of "cyber"
 - *You can use cyberchef or other tools*
 - *Report the first 4 letters*
- Get SHA256 hash of "cyber"
 - *You can use cyberchef or other tools*
 - *Report the first 4 letters*
- Compare the results

Mini-contest!

- Crack the following hash
 - *b4bf5d7e5fcf89ef8adb64ec9c624db850d10f2afef020ed9ef23892df0833af*
 - You can use crackstation or other tools
 - What is the original text?
 - What is the hashing algorithm

Hashcat

- Crackstation can only crack simple hashes. Hashcat is a more powerful tool.
- You can use the Kali lab VMs
 - Install hashcat in Kali
 - `apt-get update`
 - `apt-get install hashcat`
 - Kali build-in dictionary:
 - `/usr/share/wordlists/rockyou.txt`

Hashcat Example

```
hashcat -m 0 -a 0 target_hashes.txt  
/usr/share/wordlists/rockyou.txt
```

This is an example of dictionary attack with hashcat

-m 0 designates the type of hash we are cracking (MD5)

-a 0 designates a dictionary attack

target_hashes.txt is our input file of hashes

/usr/share/wordlists/rockyou.txt is the absolute path to the wordlist file for this dictionary attack

Hashcat tutorial:

<https://www.freecodecamp.org/news/hacking-with-hashcat-a-practical-guide/>

In the final exam

- We have obtained password dumps storing hacker passwords. It appears that it is in the format: SKY-PASS- followed by 4 digits. Can you crack it?
- 55634952e08d84ab0ed4ae5ac3517a16

Hint: You need to use mask attack (pattern matching) in hashcat

```
hashcat -m 0 -a 3 target_hashes.txt SKY-PASS-?d?d?d?d
```

Public Key Encryption/Decryption

Key Management Problems of Symmetric Encryption

- How do we distribute the secret keys in Symmetric Encryption?
 - It is a fundamental problem.
 - No good solution!!!
- What is a better solution?
 - Public Key Encryption
 - Two keys: public key and private key

Public-key Encryption

- Involves 2 distinct keys – public, private.
 - One for encryption, and the other for decryption.
- The private key is kept secret and never be divulged, and it is password protected (Passphrase).
- The public key is not secret and can be freely distributed, shared with anyone.
- It is also called “asymmetric cryptography”.
 - Two keys are mathematically related, it is infeasible to derive the private key from the public key.
 - Much slower than secret-key algorithms.

Public Key Algorithms

- Diffie-Hellman key exchange algorithm
 - ElGamal encryption system is based on this
- RSA (Rivest, Shamir, Adleman)
 - developed in 1977 at MIT
 - The most widely accepted public-key encryption algorithm
- Digital Signature Standard (DSS)
 - provides only a digital signature function
- Elliptic curve cryptography (ECC)
 - new, security like RSA, but with much smaller keys
 - Suitable for low computational power equipment such as sensors

RSA Algorithm

- Relies on the difficulty of factoring a large number
 - $n=p*q$, given n , find p,q
 - In 2009, researchers took two years to factor a 232-digit number, and this was using hundreds of machines and the most efficient algorithms we know!
 - factorization is a *computationally infeasible* problem

RSA Inventors



12301866845301177551304949
58384962720772853569595334
79219732245215172640050726
36575187452021997864693899
56474942774063845925192557
32630345373154826850791702
61221429134616704292143116
02221240479274737794080665
351419597459856902143413

=

33478071698956898786044169
84821269081770479498371376
85689124313889828837938780
02287614711652531743087737
814467999489
x
36746043666799590428244633
79962795263227915816434308
76426760322838157396665112
79233373417143396810270092
798736308917

RSA - 768 bits were broken in 2009

⇒ 232 decimals.

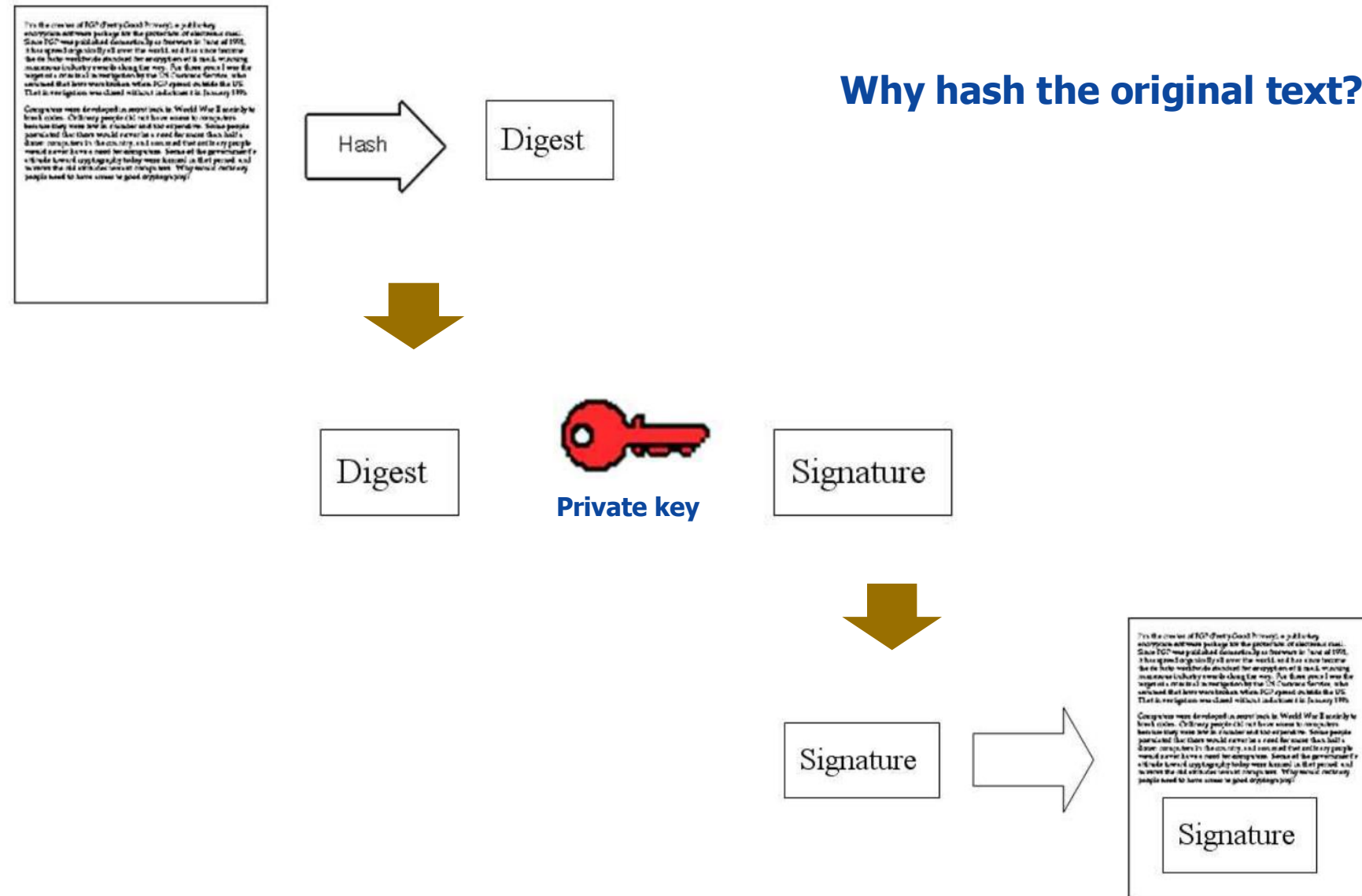
⇒ Took two years.

Digital Signature: use your private key

- Digital signature can be used in all electronic communications
 - Web, e-mail, e-commerce
- It is an electronic stamp or seal that append to the document.
- Ensure the document being unchanged during transmission.



Explanation on Digital Signature



Nonrepudiation in Digital Signature

- Nonrepudiation means that the sender cannot deny that he or she sent a message
- With digital signatures, the sender must use his or her private key
 - It is difficult to repudiate that you sent something if you use your private key
- Electronic signature law:
 - Permits the use of electronic signatures in many situations

Authentication and Integrity in Digital Signature

■ Authentication

- The ownership of a digital signature secret key is bound to a specific user, a valid signature shows that the message was sent by that user.

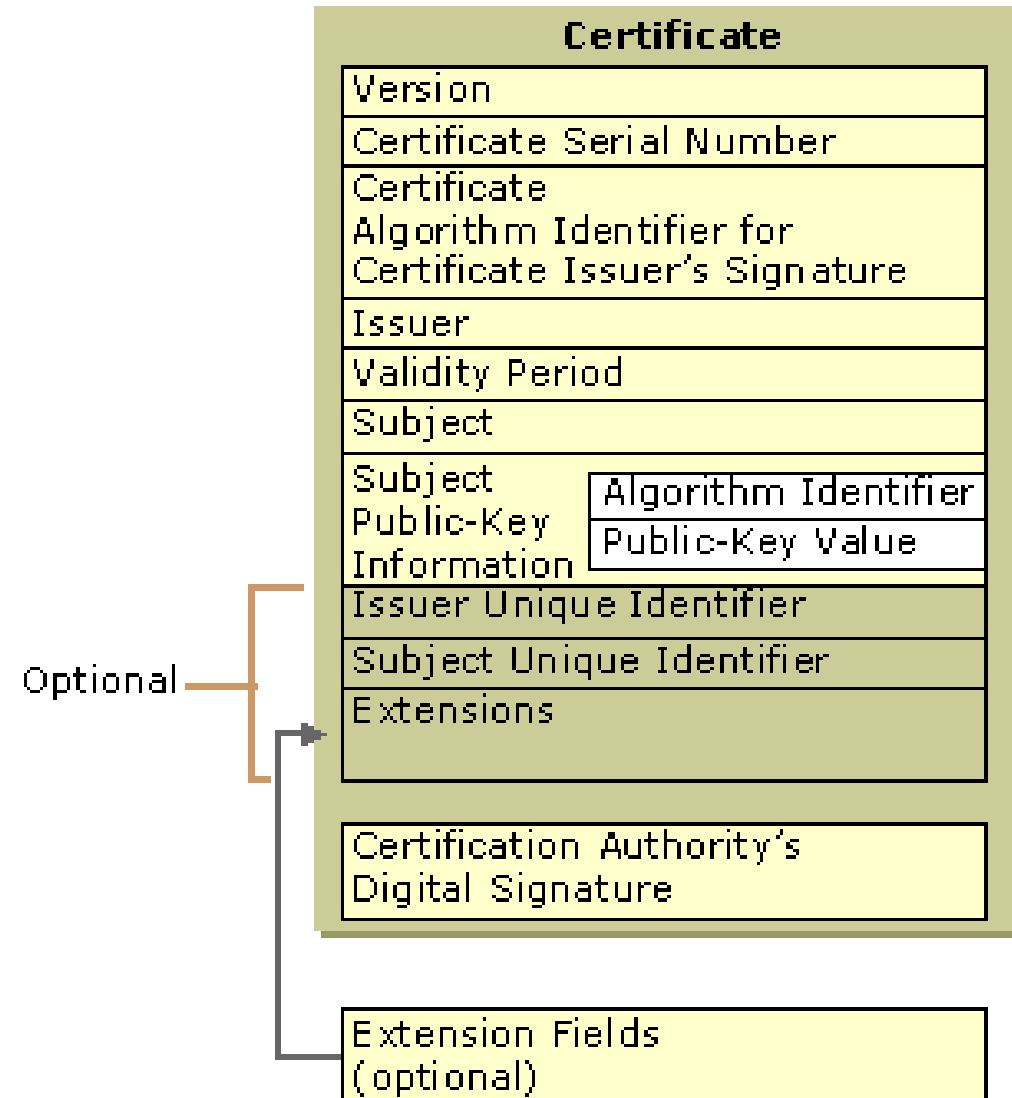
■ Integrity

- Any change in the message after signature invalidates the signature.
- Furthermore, there is no efficient way to modify a message and its signature, because of collision resistance of hash functions

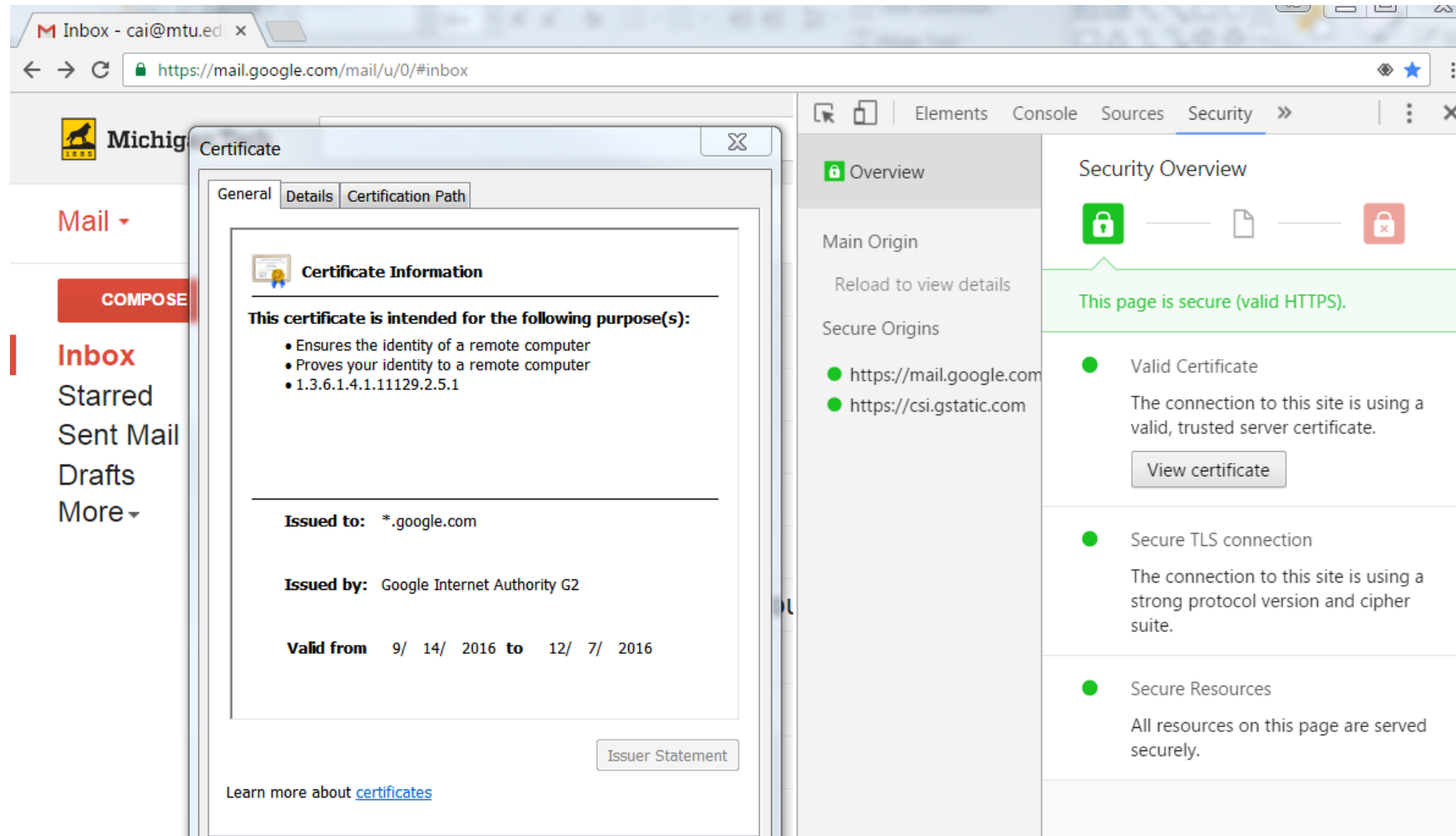
Digital Certificates: use bob's public key

- Why need digital certificates ?
 - How do you know you get the correct Amazon public key?
 - You need a trusted 3rd party to certify the real Amazon public key
- Digital Certificate is a data with digital signature from one trusted Certification Authority (CA).
 - A trusted CA issues a digital certificate to Amazon with Amazon public key info.
 - You can trust Amazon digital certificate and get Amazon public key info.

Digital Certificate



An Example: X.509 Digital Certificate



A few concepts: Public Key Infrastructure (PKI)

- PKI is a system that uses public-key encryption and digital certificates to achieve secure Internet services.
- There are 4 major parts in PKI.
 - Certification Authority (CA)
 - A directory Service
 - Services, Banks, Web servers
 - Business Users

Certification Authority (CA)

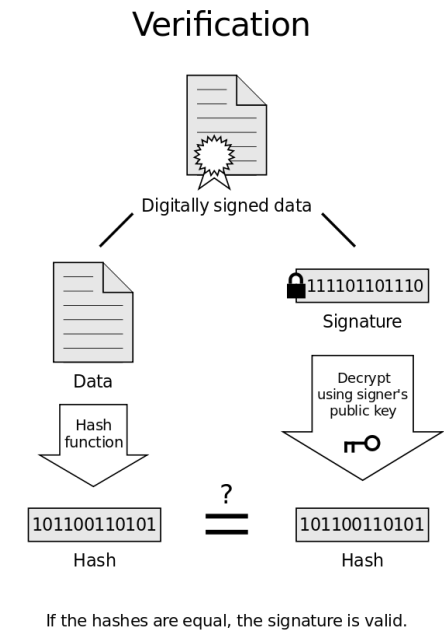
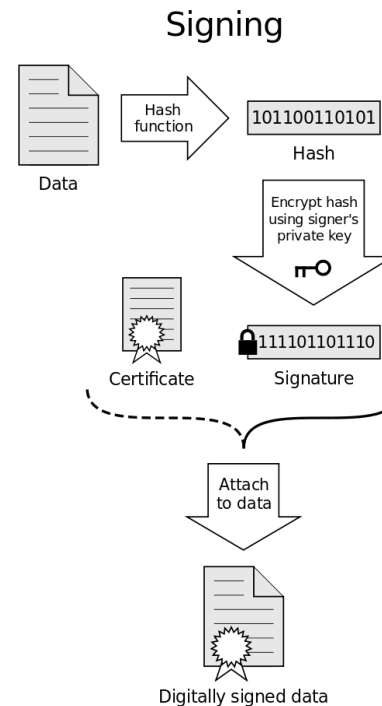
- A trusted agent who certifies public keys for general use (Corporation or Bank).
 - User has to decide which CAs can be trusted.
- Example:
 - Google is signed by GlobalSign
 - Amazon is signed by Symatec
 - You can be your own CA

A play to show PKI

- Three concepts in the play
 - Digital Signature
 - Digital Certificate
 - Certificate Authority
- Three parties in the play
 - Certificate Authority
 - Amazon
 - User/You
- Procedure:
 - Amazon gets a certificate (its public key) from CA
 - You get Amazon's certificate (its public key)
 - You and Amazon can start communication with Amazon public key
 - You and Amazon agree upon a symmetric session key and use that for all communications

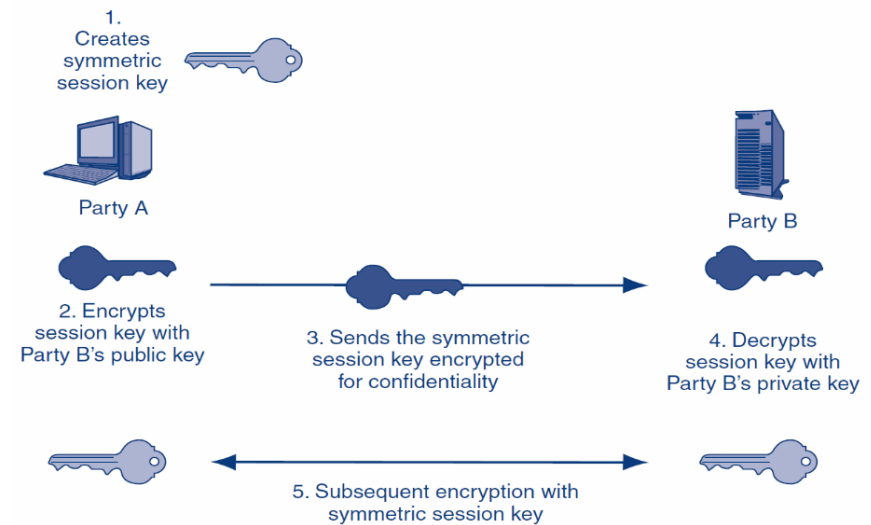
A few notes on public key cryptography

- Logically do we need to encrypt entire message?
 - No!
 - Entire message => Hashing string
 - Save time, faster, easier



A few notes on public key cryptography

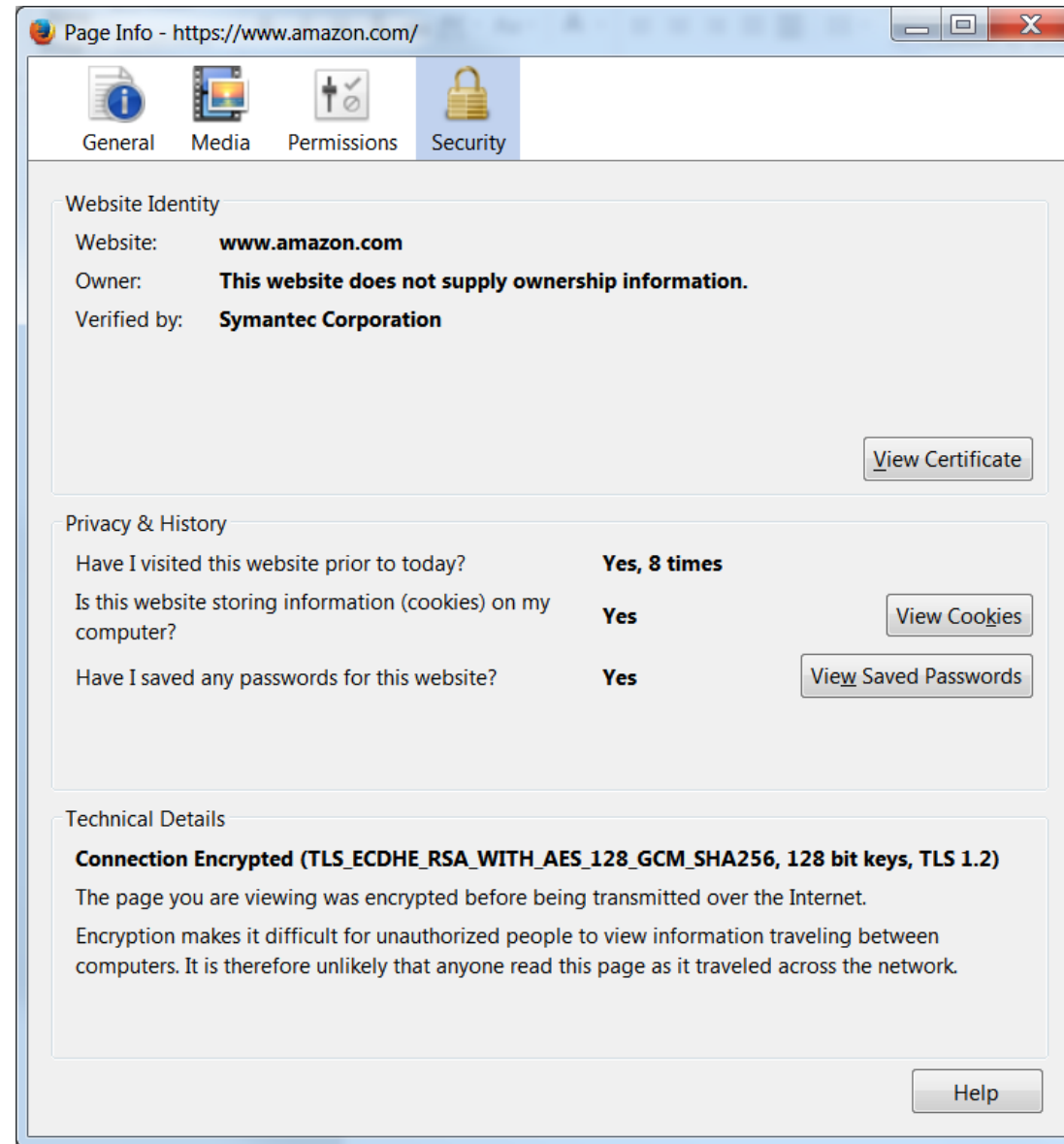
- Logically do we need to use Public Key Algorithm to encrypt the entire communication session?
 - No!
 - Public key algorithm is too too ... too slow;
 - So people use public key algorithm to negotiate a new key called session key, and use that session key for future communication.



A few notes on public key cryptography

Cipher Suite	Key Negotiation	Digital Signature Method	Symmetric Key Encryption Method	Hashing Method for HMAC	Strength
NULL_WITH_NULL_NULL	None	None	None	None	None
RSA_EXPORT_WITH_RC4_40_MD5	RSA export strength (40 bits)	RSA export strength (40 bits)	RC4 (40-bit key)	MD5	Weak
RSA_WITH_DES_CBC_SHA	RSA	RSA	DES_CBC	SHA-1	Stronger but not very strong
DH_DSS_WITH_3DES_EDE_CBC_SHA	Diffie-Hellman	Digital Signature Standard	3DES_EDE_CBC	SHA-1	Strong
RSA_WITH_AES_256_CBC_SHA256	RSA	RSA	AES 256 bits	SHA-256	Very strong

Cipher Suites Example: firefox to open amazon

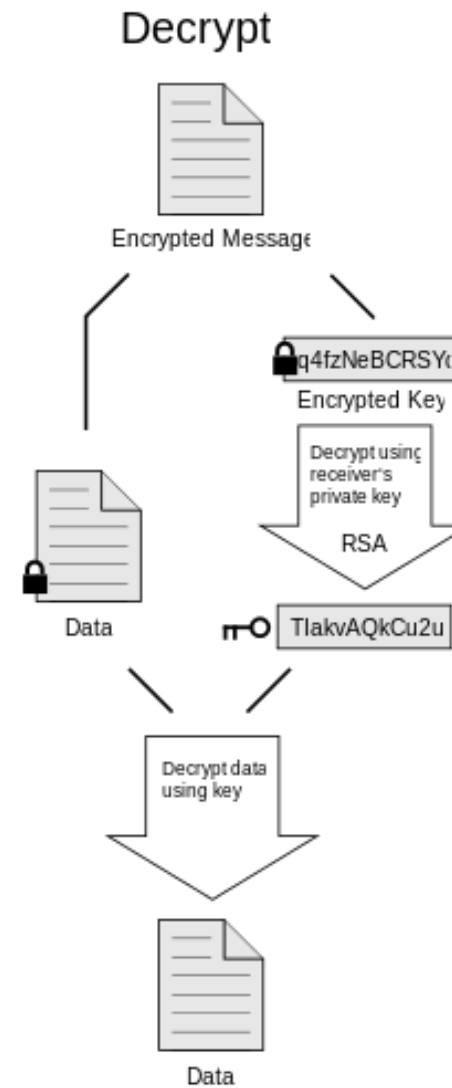
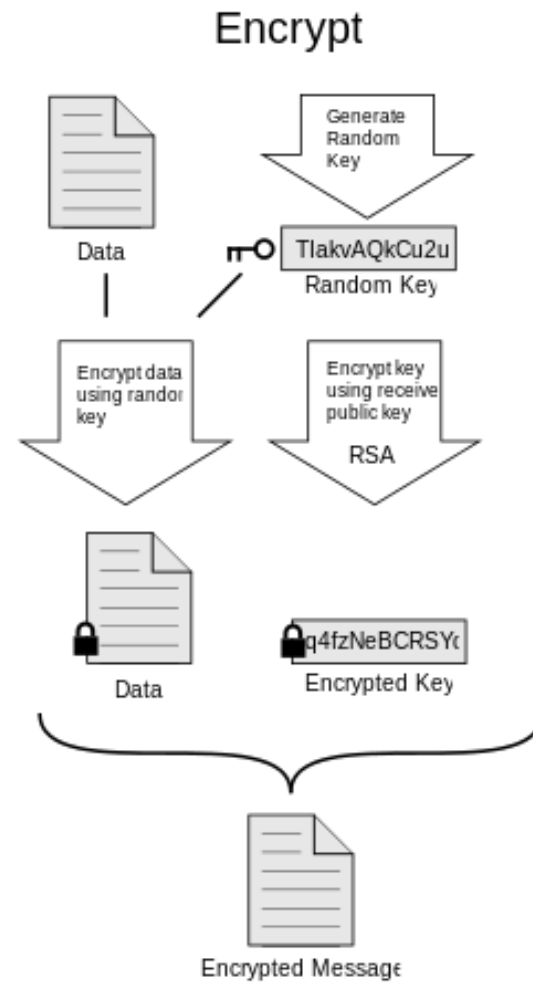


Pretty Good Privacy (PGP)

- Release in June 1991 by Philip Zimmerman
- PGP is a cryptosystem that allows user to encrypt and decrypt.
- PGP has gone through many iterations and owners since then.
- OpenPGP: Open source PGP



PGP

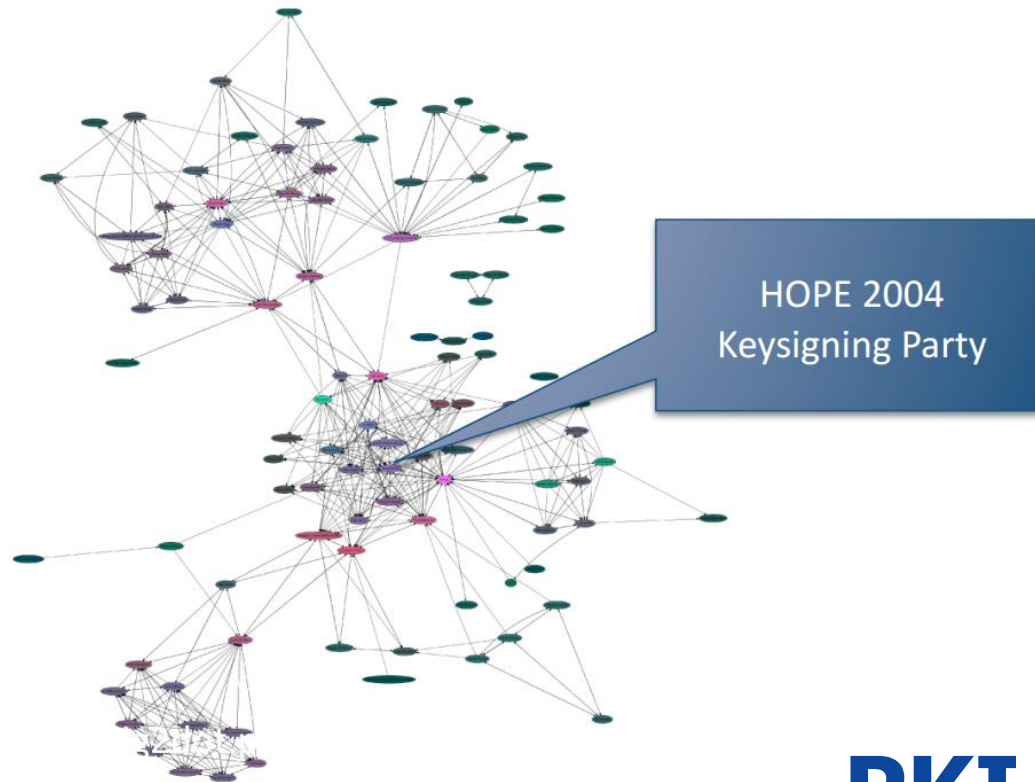


PGP Public Key of Zimmerman

- Philip R Zimmermann's Public Keys
- Current DSS/Diffie-Hellman Key:
- Key fingerprint: 055F C78F 1121 9349 2C4F 37AF C746 3639 B2D7 795E
- -----BEGIN PGP PUBLIC KEY BLOCK-----
- Version: PGP 7.0.3
- mQGIBDpU6CcRBADCT/tGpBu0EHpjd3G11QtkTWYnihZDBdenjYV2EvotgRZAJ5h4ewprq1u/zqzGBYpiYL/9j+5XDfcoWF24bsUmHXsbDSiv+XEyQND1GUdx4wVcEY5rNjArX06XuZzObvXF
XOvqRj6LskePtw3xLf5uj8jPN0Nf6YKnhfGIHRWQcG/0UAR3hMK6zcA/egvWRGsm9dJecD/18XWekt5JJeK3febJO/3Mwe43O6VNOxmMpGWOYTrhivyOb/ZLgLedqX+MeXHGdGroARZ+KxYq/a
9y5jNcivD+EyN+IiNDPD64rl00FNZksx7dijD89PblULDCtUpps2J0gk5inR+yzinf+jDyFnn5UEHI2rPFLUbXWHJXJcp0UBACBkzDdesPjEVXZdTRTLk0sfiWEdcBM/5GpNswMlK4A7A6iqJoSNJ4pO
5Qq6PYOwDFqGir19WEfoTyHW0kxipnVbvq4q2vAhSIKOqNEJGxg4DTEKecf3xCdJ0kW8dVSogHDH/c+Q4+RFQq/31aev3HDy20YayxAE94BWlSkkhaMyokAYQQfEQIAIQUCOItwVwIHABcM
gBE/xzIEHSPp6mbdtQCcnbwh33TcYQAKCRDHRjY5std5Xle4AKCh1dqtFxD/BiZMqdP1eZYG8AZgTACfU7VX8NplaGmdyz/drSDUo49AJae0lBoaWxpcCBSLiBaaW1tZXJtYW5uIDxwcnpAbWl
0LmVkdT6JAFUEEBECABUFAjpU6CcFCwkIBwMCGQEFgwMAAAACgkQx0Y2ObLXeV5WUQCfWWfTDHzSezrDawgN2Z4Qb7dHKooAoJyVnm61utdRsdLr2e6QnV5Z0yjjQBGBBARAgAGB
QI6VOKSAAoJEGPLaR3669X8JPcAnim4+Hc0oteQZrNUeuMSuirNVUr7AKC1WXJI7gwMq0Agz07hQs++POJBMokARgQQEQIABgUCOicobQAKCRDXjLzlZqdLMVBtAKDa5VPcb6NVH6tVeED
JUv+tbjp6oACeLoNtfs2rvJkgKDHWEIDmJdgy2GJAD8DBRA6WP4Y8CBzV//QUISsRAkmdAKC3TfkSSeh+poPFnMfW+/Y/+AAEEpGSUYAAQEAAAEAAQAA/9sAQwAKBwclBwYKCAglCwoK
Cw4YEA4NDQ4dFRYRGCMfJSQIHylhJis3LyYpNCKhljBBMTQ5Oz4+PiUuREIDPEg3PT47///EALUQAAIBAwMCBAMFB
-
- QQEAAABfQECAwAEEQUSITFBbHNRYQcicRQygZk5SVlpeYmZqio6Slpqeoqaqys7S1tre4ubrCw8TFxsflycrS09TV1tfY2drh4uPk5ebn6Onq8fLz9PX29/j5+v/EAB8BAAMBAQEBAQEBAQEA
AAAAABAgMEBQYHCAKKC//EALURAAIBAgQEAwQBHQQEAAECdwABAgMRBAUhMQYSQVEHYXETIjKBCBRCKaGxwQkjM1LwFWJy0QoWJDTThJfEXGBkaJicoKSo1Njc4OTpDREVGR0hJ
SINUVVZXWFlaY2RlZmdoaWpzdHV2d3h5eoKDhIWGh4iJipKTlJWWm5iZmqKjpKWmp6ipqrKztLW2t7i5usLDxMXGx8jJyLT1NXW19jZ2uLj5OXm5+jp6vLz9PX29/j5+v/aAAwDAQACEQMRAD8A
9mooooAKKKKACsjW/Eum6FGTds7pcfLEv3j/AlfjWV428XHQRf7HY4e/HXlxEvqfevH7y8lupXmmuJppWOZJC+AD9aly7GkIX1Z3OpfE3Up3K2EUUumcdN7fy/pWLL4415wPM1GWPJyNpK/0Fc5
btG/Pktkfx7yTVhYAGLsAxbryf5c5rNvzNIG3Q6yz8ZaxEyudQkcZ+7JtYH867PRfG9nflsd7/o8p/il+U/4V5EI/IGV+XUGfnHy9iUsiGSa6q6Jew1XpTDJvAAICDACNUV4K2PS6h574Z3NaBslQe5jkV
O48MSohjC6s29CjPhlU79cQIYWmBpuNfwroZ6zltz6Y2Fm65V0lfvVicR7zvFFCOhahMuk1cr+Qp936OMEq9sLZGxTjClgwrHGS7YpMSZrEC7bpOmERjo4F/n5YmCHJCH8QzCOc9+80gjVEsHi
JVABrC8yykjKL5x1V/PSArE4QtMLbkBPGmQYOW8bx6jChO43QjUzbqRfBMHZqWVJyolIZCp+n13XM4+NO/cDVsz8bjch0LIOyMrT85n24fyXRIP0s7BFjLm59Jjh4djuJWikJawWETlypAy86OY
RRuwCblyNauBeTKy+avZvF2oLvph4UnudpC06/O0jkj2lQpn9EEUw11RwO6sq9zYTwaUyKerN00cbCfyiZl01Clo0btcTO6hQK3c67PaloJ9IVH8/mH7LuqKMLDH5ugkpzmed/8SorfqVkakne6b4
mRySFCBXaVZoKmDHzch2oSSMhM9exyh6dzi1bGu6JAEwEGBECAAwFAjpU6CcFGwwAAAAACgkQx0Y2ObLXeV7bQCg+N+fl3bzqF9+fB50J5sFHVHm7hYAn0+9AFDI5ncnr4D7
ReMDIYoLZwRR=Bgy+
- -----END PGP PUBLIC KEY BLOCK-----

Which public keys can you trust?

Web of Trust



PKI vs PGP

OpenPGP supports both the traditional "web of trust" model and a hierarchical model

The story of Phil Zimmerman

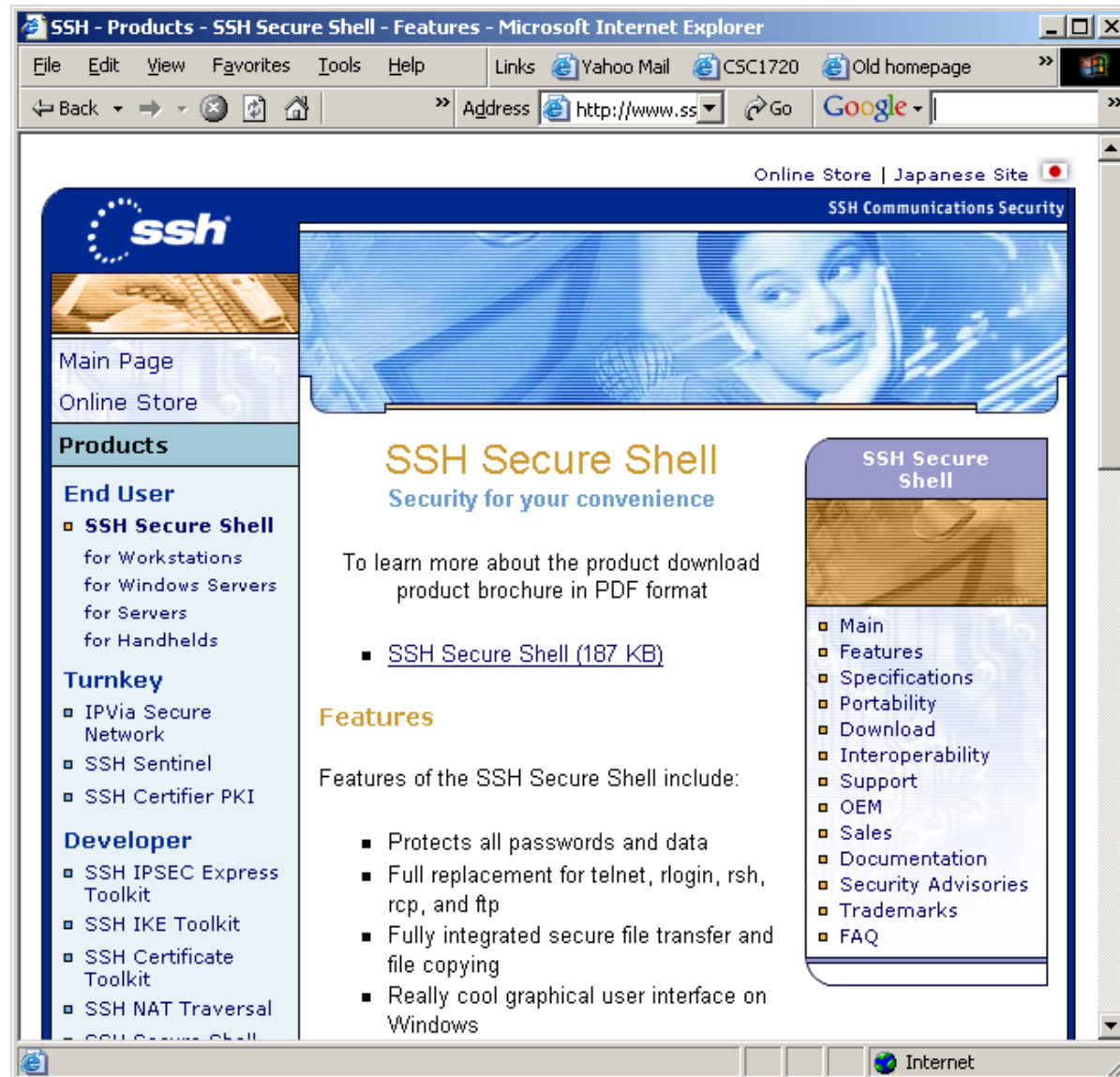
- Video (8 min)
 - <https://www.youtube.com/watch?v=cZD36L3BXXs>
- How Joe Biden Accidentally Helped Us All E-Mail in Private
 - <https://www.wired.com/2012/12/joe-biden-private-email/>



Secure Web Communication

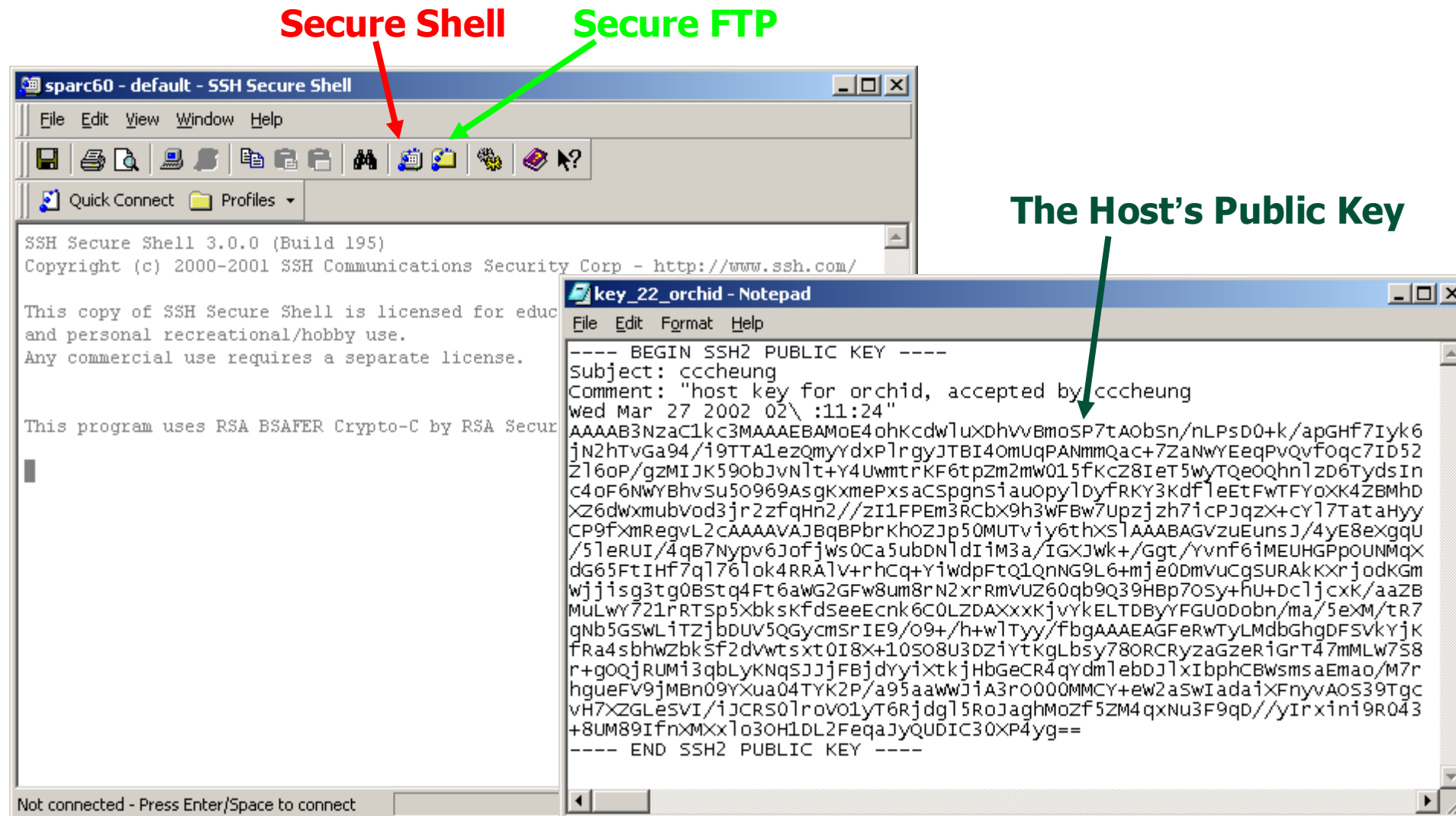
- Server authentication is necessary for a web client to identify the web site it is communicating with.
- Get a server certificate from a CA.
- Install a server certificate at the Web server.
- Enable SSL on the Web site.
- Client authentication – Client certificates
- https://
- https is the prevailing web protocol now.
 - Stop using http.

Secure SHell (SSH)



- Provide an encrypted secure channel between client and server.
- Replacement for telnet and ftp.

Secure Shell & Secure FTP



Replay Attacks and Defenses

- Replay Attacks
 - Capture and then retransmit an encrypted message later
 - May have a desired effect
 - Even if the attacker cannot read the message

Replay Attacks and Defenses

- Thwarting Replay Attacks
 - Time stamps to ensure freshness of each message
 - Sequence numbers so that repeated messages can be detected
 - Nonces
 - Unique randomly generated number placed in each request message
 - Reflected in the response message
 - If a request arrives with a previously used nonce, it is rejected

Yellow Tag Question

```
User7:$6$V8LZ12VD$6P30P.An9faPSFn0p0mFXvgqTR.jWKwqSBbd0xMDIOJCu57020RhPGpwna0xBeN  
bZu.jCpsndNF/ee.m/u/5dM3/:16332:0:99999:7:::
```

This screenshot is taken from etc/shadow file on Redhat 7.
\$6\$ means hsa512 hashing algorithm.
The string inside the red box is hsa512 output.
But why the length of the string is 87? Please explain!

Hint: the output string is base64-encoded.

Text content	M								a								n							
ASCII	77 (0x4d)								97 (0x61)								110 (0x6e)							
Bit pattern	0	1	0	0	1	1	0	1	0	1	1	0	0	0	0	1	0	1	1	0	1	1	1	0
Index	19								22								5							
Base64-encoded	T								W								F							

What are breakable now?

Depends on key length as well as algorithm

- 3DES uses 112 or 168 bit key, but it has design problem, not safe.
- 64 bit key RC5 were broken in 2003; 72 bit key RC5 are almost broken by distributed net.
- 80 bit key of symmetric key algorithms are very likely to be broken now.

Mini-Contest: If people can break 64 bit key in 2003, based on Moore's Law, what is the length people can break in 2014?

What are breakable now?

- AES use 128 or 256 bit key. 128 bits are still widely used, but considered not enough for high sensitive data.
 - 2010, paper "chosen-key-relations-in-the-middle" described a practical approach to attacks on AES-128.
 - 2010, side channel attack: with root privilege, people can break OpenSSL using AES-128 "near real time".
 - Use 256 bit AES if possible
- Hashing algorithms like MD5 (128 bit) and SHA1 (160 bit) were all broken.
 - They were used to store Linux/Unix password!

Google Achieves First-Ever Successful SHA-1 Collision Attack

📅 Thursday, February 23, 2017 👤 Swati Khandelwal

 69  Like 8.6K  Share 9142  Tweet 998  Share 831  Share 11.5K

Collision Attack: Two Different Documents, But Same SHA-1 Hash Fingerprint

SHAttered

The first concrete collision attack against SHA-1
<https://shattered.io>



Marc Stevens
Pierre Karpman



Elie Bursztein
Ange Albertini
Yarik Markov

SHAttered

The first concrete collision attack against SHA-1
<https://shattered.io>



Marc Stevens
Pierre Karpman



Elie Bursztein
Ange Albertini
Yarik Markov

└─ sha1sum *.pdf

38762cf7f55934b34d179ae6a4c80cadccbb7f0a 1.pdf

38762cf7f55934b34d179ae6a4c80cadccbb7f0a 2.pdf

└─ /tmp/sha1

└─ sha256sum *.pdf

2bb787a73e37352f92383abe7e2902936d1059ad9f1ba6daaa9c1e58ee6970d0 1.pdf

0.64G 8-11h

What are breakable now?

- 1999, RSA-155 (512 bits) were broken .
- 2002, RSA-158
- 2009, RSA-768 (768 bits, 232 digits) were broken.
- RSA of 1024 bits is considered to be no longer safe enough.
 - Use RSA-2048 if possible